

커널 hwrng TPM 통신 암호화

1. 개요

항목	내용
대상	커널 hwrng(tpm-rng-0)가 TPM에서 난수를 받아 오는 TPM2_GetRandom 통신
구현	recipes-kernel/linux/files/6.6/0005-tpm-hmac-sessions.patch (CONFIG_TCG_TPM2_HMAC=y)
기준	linux-6.12.112의 TPM HMAC 세션 코드를 6.6.116에 백포트 + mainline 수정
관련 문서	tpm-spi-link-encryption.md (작업 내용), tpm-spi-link-encryption-test-procedure.md 4장 (검증 절차)

2. 이전과 달라진 점

구분	이전 (패치 전)	이후
명령 형식	TPM2_GetRandom을 세션 없이 보냄 (태그 0x8001)	HMAC 세션을 붙여 보냄 (태그 0x8002, 속성 0x41 = continue + encrypt)
SPI에 보이는 응답	난수 바이트가 평문	AES-128-CFB 암호문
무결성	없음. 중간에서 응답을 바꿔도 알 수 없음	명령과 응답 모두 HMAC-SHA256 검증. 위조되면 응답을 버림
보호 범위	커널 CRNG에 섞이는 TPM 난수, /dev/hwrng를 읽는 rngd 출력	같음. 두 경로 모두 tpm2_get_random() 한 곳을 지나므로 함께 보호됨

이전에는 SPI 버스를 도청하면 커널 엔트로피 입력과 rngd 출력에 쓰이는 난수를 그대로 볼 수 있었다. 이제 그 바이트는 TPM과 커널 사이에서만 풀리는 암호문으로 지나간다.

3. 부팅 시 초기화

TPM SPI 드라이버 probe 중 tpm_chip_register() → tpm2_sessions_init() 에서 한 번 실행된다.

1. null primary 생성

- TPM2_CreatePrimary로 null hierarchy에 ECC P-256 저장 키를 만든다.
- null hierarchy의 seed는 TPM이 리셋될 때마다 바뀌므로, 이 키는 부팅마다 새로 생기는 일회용 키이다.
- 비밀 키는 TPM 밖으로 나오지 않는다.

2. 이름과 컨텍스트 저장

- 키의 이름(공개 영역의 해시)을 커널이 기억하고 /sys/class/tpm/tpm0/null_name으로 보여 준다.
- ContextSave로 키 컨텍스트를 저장한 뒤 핸들은 TPM에서 내린다.
- 이후 세션을 열 때마다 ContextLoad로 다시 올리고 이름을 비교한다. 다르면 TPM이 바뀌치기됐거나 리셋된 것으로 보고 TPM을 비활성화한다 (TPM_CHIP_FLAG_DISABLE).

3. DRBG 해시 준비 (부팅 경고 수정, 32251aa8)

- 세션의 ECDH 비밀 키는 커널 기본 DRBG(drbg_nopr_hmac_sha512)로 만든다.

- TPM probe는 비동기로 실행되는데, 그 안에서 DRBG의 hmac(sha512) 인스턴스를 처음 만들면 모듈 로드를 요청해 커널 WARNING이 났다.
- 그래서 부팅 초기 device_initcall에서 CRYPTO_NOLOAD로 이 인스턴스를 미리 만들어 둔다.

4. 세션 수립 (salt 교환)

hwrng 읽기 시 살아 있는 세션이 없으면 tpm2_start_auth_session() 이 실행된다.

순서	커널	버스에 실리는 값	TPM
1	ContextLoad로 null key를 올리고 이름 확인	null key 컨텍스트 (TPM이 암호화해 둔 것)	키 로드
2	임시 ECDH 키쌍 생성 (비밀 d_k, 공개 Q_k), $Z = d_k \times Q_{null}$ 계산	없음	
3	StartAuthSession 전송 (HMAC 세션, AES-128-CFB, SHA-256)	Q_k(공개점), nonceCaller →	$Z = d_{null} \times Q_k$ 계산 (TPM 안의 비밀 키 사용)
4		← 세션 핸들, nonceTPM	세션 생성
5	salt = KDFe(SHA-256, Z, "SECRET", ...), sessionKey = KDFa(SHA-256, salt, "ATH", nonceTPM, nonceCaller)	없음	같은 계산으로 같은 sessionKey 얻음
6	FlushContext로 null key 내림	null key 핸들	키 내림

- 버스에 실리는 값은 Q_k(공개점), 두 nonce, 세션 설정뿐이다.
- salt의 원천인 Z는 커널의 임시 비밀 키 d_k 또는 TPM 안의 null key 비밀 키 d_null 중 하나가 있어야 계산된다. 둘 다 버스를 지나지 않으므로 도청자는 sessionKey를 알 수 없다.
- 세션 설정(ECDH P-256, AES-128-CFB, SHA-256)은 upstream 커널에 고정된 값이며, TCG PC Client 플랫폼 TPM이 반드시 지원하는 조합이다.

5. 명령마다: 누가 암호화하고 누가 복호화하나

TPM2_GetRandom 한 번(최대 32B)의 흐름이다.

순서	커널	버스에 실리는 값	TPM
1	새 nonceCaller, 속성 continue + encrypt(0x41). 명령 HMAC = HMAC(sessionKey, cpHash nonces 속성)	GetRandom(요청 바이트 수, 세션, 명령 HMAC) →	
2			명령 HMAC 검증 (틀리면 거부). 난수 생성, 새 nonceTPM
3			카·IV = KDFa(sessionKey, "CFB", nonces). 난수를 AES-128-CFB로 암호화. 응답 HMAC = HMAC(sessionKey, rpHash nonces 속성)
4		← 암호화된 난수, nonceTPM, 응답 HMAC	

순서	커널	버스에 실리는 값	TPM
5	응답 HMAC 검증 (틀리면 버림)		
6	같은 KDFa로 키·IV 계산 → AES-128-CFB 복호화 → 평문 난수를 hwrng 코어(CRNG, /dev/hwrng)로		

역할별로 정리하면 다음과 같다.

단계	하는 쪽	내용
명령 HMAC 생성	커널	<code>tpm_buf_fill_hmac_session()</code> . 요청 파라미터(바이트 수)는 비밀이 아니므로 암호화하지 않음 (decrypt 속성 꺼짐)
명령 HMAC 검증	TPM	위조된 명령 거부
응답 난수 암호화	TPM	<code>encrypt</code> 속성이 켜져 있어 응답의 첫 파라미터(난수 버퍼)를 암호화
응답 HMAC 생성	TPM	암호화된 파라미터를 포함해 계산
응답 HMAC 검증	커널	<code>tpm_buf_check_hmac_response()</code> . 틀리면 응답을 버리고 오류
응답 난수 복호화	커널	<code>lib/crypto/aescfb.c</code> (이번 백포트에 포함)

- 이 경로에서는 **TPM이 암호화하고 커널이 복호화**한다.
- 반대 방향(커널이 명령 파라미터를 암호화하고 TPM이 복호화하는 `decrypt` 속성)도 코드에는 있지만 `GetRandom`에는 쓰이지 않는다.
- nonce가 명령마다 바뀌므로 암호화 키와 IV도 매번 달라진다. 같은 세션 안에서 응답을 다시 보내는 재전송도 HMAC 검증에서 걸린다.

6. 세션 수명 (lazy flush)

- hwrng 호출 사이에는 세션을 닫지 않고 유지한다. 그래서 평소에는 명령 1개당 `GetRandom` 하나만 나간다.
- 아래 시점에는 커널 세션을 닫는다.
 - 사용자 공간이 `/dev/tpm*`로 명령을 보내기 직전 (`tpm-dev-common.c`)
 - suspend, shutdown, 드라이버 해제
- 닫힌 뒤 다음 hwrng 읽기에서 4장의 세션 수립(ContextLoad → StartAuthSession → FlushContext)을 다시 한다.
- 6.12.y는 호출마다 세션을 닫는다. 이 동작은 mainline에서 가져온 수정이다.

7. 성능

항목	값
세션 사용 시	<code>GetRandom(32B)</code> 명령당 약 24 ms (4096B 읽기 3.1초)
세션 없을 때	명령당 약 9 ms
유휴 시 커널 hwrng 호출	30초에 1회 (TPM 명령 2개)

느려지지만 유휴 시 호출 빈도가 낮아 실사용 영향은 작다.

8. 한계

- 수동 도청만 막는다. null key는 인증서로 검증하지 않는다. 부팅 후 키가 바뀌는 것은 이름 비교로 잡지만, 부팅 시점부터 TPM 행세를 하는 능동 인터포저가 자기 키를 null key로 내미는 것은 막지 못한다.
- 첫 세션의 ECDH 비밀 키는 커널 CRNG 초기화 전에 만들어진다. 그 시점의 커널 DRBG는 jitterentropy와 초기 get_random_bytes로 시드되고, CRNG가 준비되면 다시 시드된다.
- 세션 암호(ECDH P-256, AES-128-CFB, HMAC-SHA-256)는 OpenSSL FIPS 경계 밖이다. 전송 보호용이며 키 생성에는 쓰이지 않는다.

9. 디바이스에서 확인하는 법

자세한 절차는 `tpm-spi-link-encryption-test-procedure.md` 4장을 따른다. 요점만 적으면 다음과 같다.

```
zcat /proc/config.gz | grep CONFIG_TCG_TPM2_HMAC      # =y
cat /sys/class/tpm/tpm0/null_name                    # 000b... (null key 생성·검증 성공)
T=/sys/kernel/tracing
echo 'p:tpmcmd tpm_transmit tag=+0(%r1):x16 cc=+6(%r1):x32 attr=+52(%r1):x8' > $T/
kprobe_events
echo 1 > $T/events/kprobes/enable; echo > $T/trace; echo 1 > $T/tracing_on
head -c 64 /dev/hwrng > /dev/null
echo 0 > $T/tracing_on; grep tpmcmd $T/trace
echo 0 > $T/events/kprobes/enable; echo > $T/kprobe_events
```

head 프로세스의 GetRandom이 tag=0x280 cc=0x7b010000 attr=0x41(리틀 엔디언 표기: 태그 0x8002, 명령 0x17B, 속성 continue + encrypt)로 나오면 세션 암호화가 적용된 것이다.